🧩 Detailed BRD: Account Management

Overview

SMART-STOCK ensures that the hardware store's inventory and financial data remain secure while tracking employee accountability. The Accounts and Access module controls who can enter the system, assigns specific roles (Admin vs. Staff), restricts what each role can see, and ensures every finalized transaction is explicitly tied to the cashier who handled it.

Scope

- Creation of user accounts by an Administrator
- Role assignment (Admin or Staff)
- Signing in and signing out
- Session duration and tracking the active user for sales logs
- Changing/resetting passwords manually by Admin
- Restricting page access based on user role

Out-of-Scope

- Self-service account registration (staff cannot create their own accounts)
- Sign in with Google / Apple / Facebook
- Two-factor authentication (2FA)
- Email-based automated password recovery (Admin handles resets)
- Customer/buyer accounts

Functional Requirements

Requirement	Actor	Priority	Rationale

The system shall allow an Admin to create new accounts with a designated username, password, and role.	Admin	Must	Only the store owner should authorize who has access to the POS and inventory.
The system shall require a registered user to sign in using their assigned username and password.	User	Must	Secures the system from unauthorized access.
The system shall automatically redirect Staff accounts strictly to the simplified POS sales interface upon successful login.	System	Must	Fulfills the requirement for a "super basic GUI" and prevents staff from seeing Admin data.
Admins should be redirected to the main dashboard (inventory and order suggestions) after login.	System	Must	Gives the store owner immediate access to overall business status.

The system shall attach the active session's username to every finalized sale transaction.	System	Must	Allows the Admin to track exactly who handled which transaction.
Reject access to Admin-only routes if the active session is a Staff role.	System	Should	Prevents technical workarounds to view sensitive financial/inventory data.
The system shall allow an Admin to deactivate a Staff account instead of deleting it.	Admin	Should	Preserve historical transaction data tied to that employee after they leave the company.

Non-Functional Requirements

Category	**Requirement**
Security	Passwords shall be stored using hashing, never in plain text or a reversible form.
Performance	A sign-in attempt shall complete within 1.0 second.
Usability	The login screen shall consist only of username, password, and a submit button with no distracting elements.

Security	No Staff account shall be able to read or modify Admin dashboard data by any route, including direct URL manipulation.

Constraints

- No external email service integration; all password resets must be done manually by the Admin within the system.
- Sessions are stored in the single relational database.

Limitations

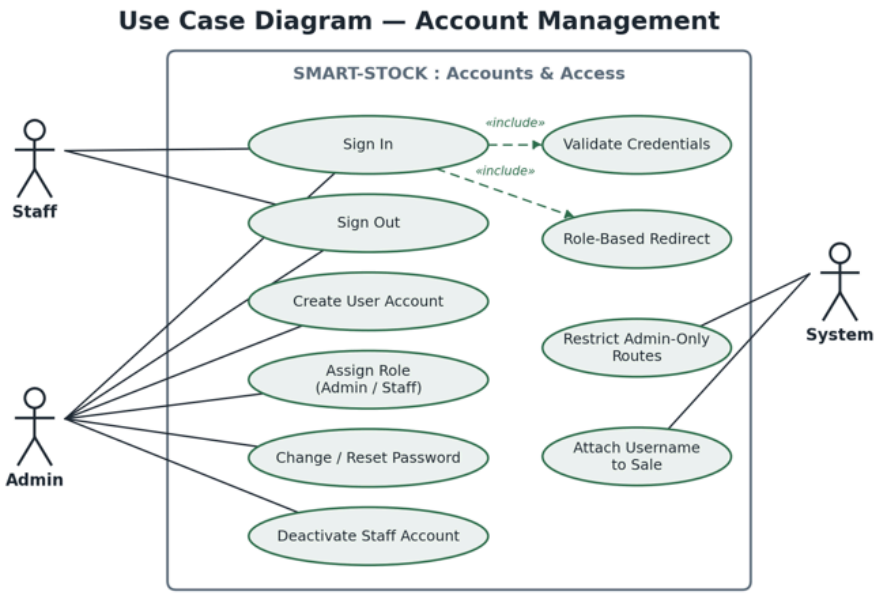
- Because accounts cannot be fully deleted (to preserve sales history), the database will retain inactive user records indefinitely.

Assumptions

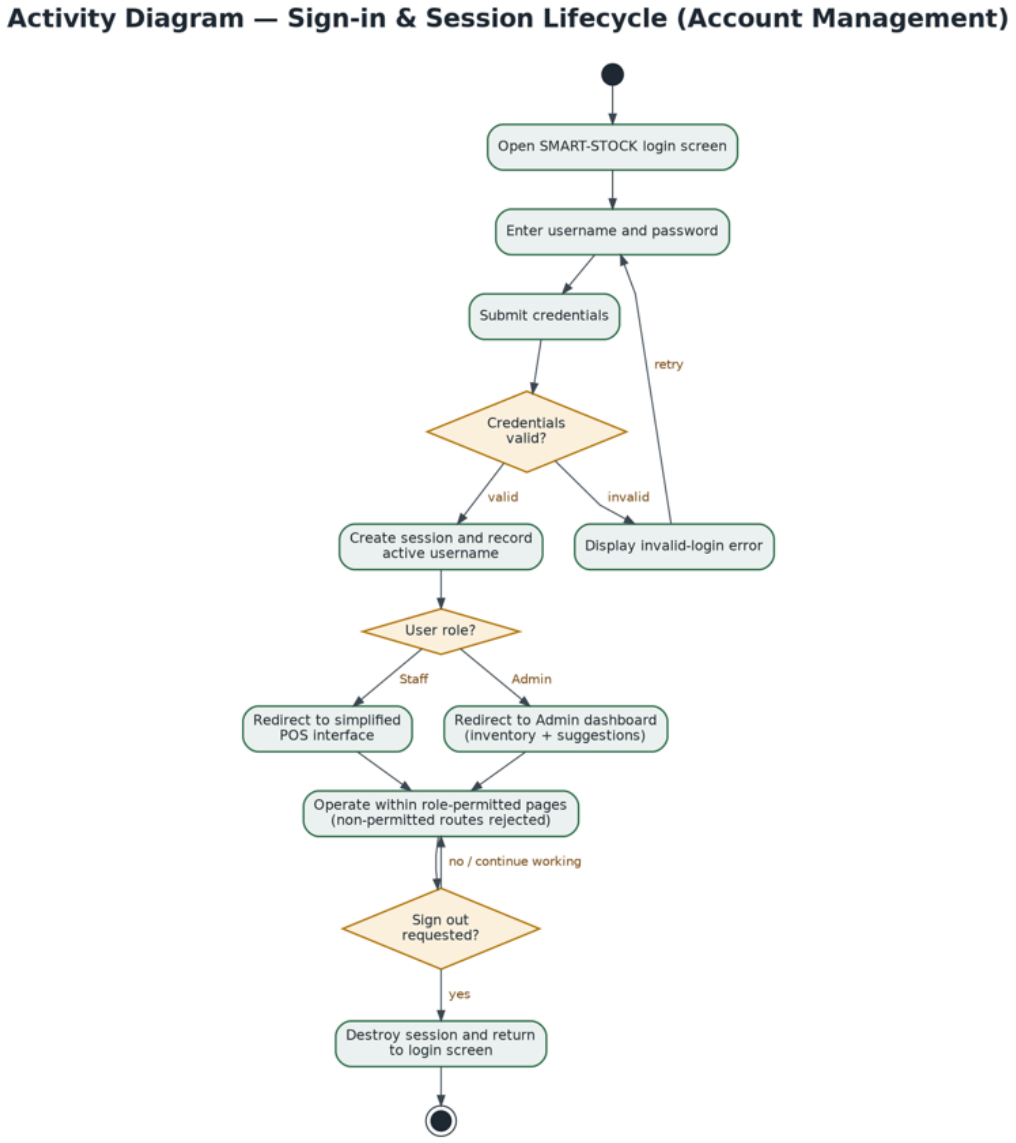
- One person, one account. Staff members do not share accounts with each other during shift changes.
- Users have cookies enabled on the store's terminal browser.
- The system operates on a trusted local network or secure terminal within the hardware store.

Requirements Model

- **Use Case Diagram**



- **Business rules**
  - Staff Role = POS Access Only.
  - Admin Role = POS + Inventory + Demand Suggestions + User Management.
- **Activity Diagram**
  - *Sign-in and session lifecycle*



- **State model**
  - *Account Lifecycle*

